Elaboração do RIPD

Referência: Guia/Modelo PPSI/SGD-MGI, versão 2.0, maio/2023, e Lei nº 13.709/2018 — LGPD.

Roteiro prático para a elaboração do Relatório de Impacto à Proteção de Dados Pessoais

Finalidade da apresentação

- **Orientar a elaboração de um RIPD juridicamente fundamentado, tecnicamente consistente e auditável, capaz de demonstrar:**

1. Contexto
Qual o tratamento de dados pessoais será avaliado.

2. Riscos
Quais impactos podem atingir titulares.

3. Controles
Quais medidas reduzem ou justificam o risco residual.

Referências principais: LGPD, Arts. 5º, XVII; 6º; 10, §3º; 32; 38; 46; 50.

O que é RIPD?

RIPD é a documentação do controlador que contém a descrição dos processos de tratamento de dados pessoais que podem gerar riscos às liberdades civis e aos direitos fundamentais, bem como as medidas, salvaguardas e mecanismos de mitigação de risco.

> Na LGPD, o RIPD não é apenas um formulário: é instrumento de **responsabilização**, **governança**, **prevenção** e **prestação de contas**.

LGPD, Art. 5º, XVII; Art. 6º, X; Art. 50, §2º, I, “d”.

Quando elaborar o RIPD?

O momento preferencial é **antes do início do tratamento**, para que os riscos sejam avaliados preventivamente (*Privacy by Design*).

Antes do tratamento

Projetos, sistemas, contratações, integrações, novas tecnologias e mudanças relevantes.

Durante o tratamento

Quando for identificado alto risco, alteração de finalidade, novo compartilhamento ou nova orientação regulatória.

A ANPD também pode solicitar o RIPD ao controlador.

LGPD, Arts. 10, §3º; 32; 38.

Situações típicas de necessidade

dados sensíveis **crianças e adolescentes** **larga escala** **decisão automatizada** **vigilância**
nova tecnologia **compartilhamento relevante** **risco de dano moral ou patrimonial**

O modelo recomenda elaborar ou atualizar o RIPD sempre que houver possibilidade de impacto à privacidade, inclusive por mudanças em sistemas, fluxos de dados, normas internas, finalidades ou estruturas administrativas.

LGPD, Arts. 5º, II; 12, §2º; 14; 20; 42.

Quem participa?

Controlador

Responsável pelas decisões sobre o tratamento e pela elaboração do RIPD.

Operador

Executa tratamento em nome do controlador e deve fornecer subsídios técnicos e operacionais.

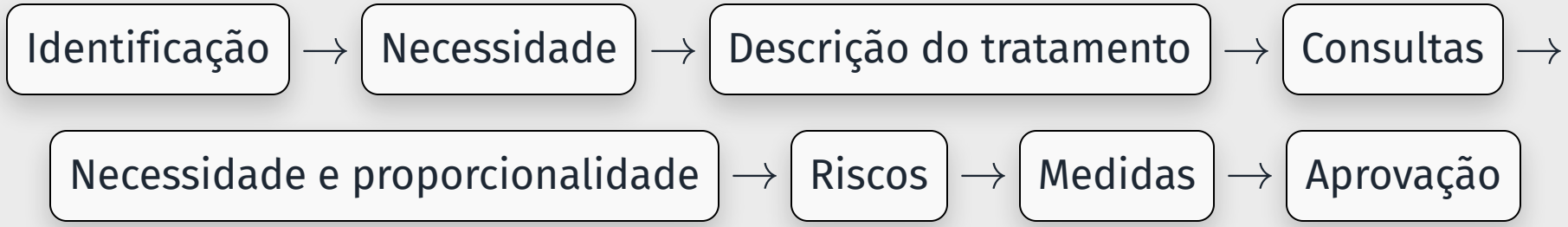
Encarregado

Canal com titulares e ANPD; contribui na avaliação de conformidade e transparência.

Também podem ser consultados: gestores do processo, área jurídica, segurança da informação, auditoria, TI, contratos e unidades finalísticas.

LGPD Art. 5º, inciso XVII, e Art. 38.

Estrutura recomendada do RIPD



Seção	Pergunta central
Identificação	Quem decide, quem executa e quem atua como encarregado?
Descrição	Que dados são tratados, por qual fluxo e finalidade?
Riscos e medidas	O que pode afetar titulares e como reduzir o risco?
Aprovação	Quem assumiu ciência, validação e responsabilidade?

Passo 1 — Identificar agentes e responsabilidades

Registrar, no mínimo:

- **Controlador:** órgão ou entidade que decide as finalidades e meios do tratamento.
- **Operador:** pessoa natural ou jurídica que trata dados em nome do controlador.
- **Encarregado:** canal de comunicação com titulares e ANPD.
- **Responsável pela elaboração:** unidade ou pessoa designada para consolidar evidências.

> A identificação evita ambiguidade decisória e facilita a responsabilização institucional.

LGPD, Art. 5º, VI, VII, VIII e XVII; Art. 41.

Passo 2 — Justificar a necessidade do RIPD

A seção deve responder: **por que este tratamento exige avaliação de impacto?**

Exemplos de fundamentos:

- alto risco às liberdades civis e aos direitos fundamentais;
- tratamento de dados pessoais sensíveis;
- tratamento de dados de crianças ou adolescentes;
- uso de decisão automatizada;
- compartilhamento com outro controlador ou operador;
- solicitação ou determinação da ANPD.

LGPD, Arts. 4º, §3º; 5º, XVII; 10, §3º; 14; 20; 32; 38.

Passo 3 — Descrever o tratamento

A descrição deve cobrir quatro dimensões:

Natureza

Como os dados são coletados, usados, armazenados, compartilhados e eliminados.

Escopo

Quais dados, titulares, volume, frequência, retenção e abrangência geográfica.

Contexto

Relação com titulares, expectativas, vulnerabilidades e ambiente institucional.

Finalidade

Objetivo legítimo, resultado esperado e hipótese legal aplicável.

LGPD, Arts. 5º, X; 6º, I a III; 7º; 11.

Passo 4 — Mapear dados, titulares e fluxos

Uma boa descrição deve permitir responder:

Elemento	Exemplo de pergunta
Dados pessoais	Quais campos são tratados? Há CPF, endereço, imagem, biometria, saúde?
Titulares	Servidores, jurisdicionados, terceirizados, magistrados, crianças?
Fontes	Formulário, sistema, processo judicial, contrato, planilha, API?
Compartilhamentos	Para quem os dados são enviados e com qual fundamento?
Retenção	Por quanto tempo os dados permanecem armazenados?

LGPD, Arts. 5º, I, II e X; 6º, III, IV, V e VI.

Passo 5 — Validar necessidade e proporcionalidade

O RIPD deve demonstrar que o tratamento é **adequado, necessário e proporcional** à finalidade declarada.

Minimização

Coletar apenas dados pertinentes, proporcionais e não excessivos.

Qualidade

Manter dados exatos, claros, relevantes e atualizados.

Transparência

Informar titulares de modo claro, adequado e ostensivo.

Direitos do titular

Prever resposta a confirmação, acesso, correção, anonimização, eliminação e informação.

LGPD, Arts. 6º, I, II, III, V e VI; Art. 18.

Passo 6 — Consultar partes interessadas

Registrar as manifestações relevantes das áreas consultadas:

- jurídico: base legal, sigilo, publicidade, retenção e responsabilidade;
- segurança da informação: controles, vulnerabilidades, logs, criptografia, acessos;
- gestão do processo: finalidade, necessidade operacional e riscos de negócio;
- operador: arquitetura, suboperadores, armazenamento e descarte;
- encarregado: direitos dos titulares, transparência e comunicação.

> O registro de opiniões convergentes e divergentes fortalece a prestação de contas.

LGPD, Art. 6º, X; Art. 39; Art. 41.

Passo 7 — Identificar e avaliar riscos

Para cada risco, registrar:

Evento
o que pode acontecer.

Probabilidade
chance de ocorrência.

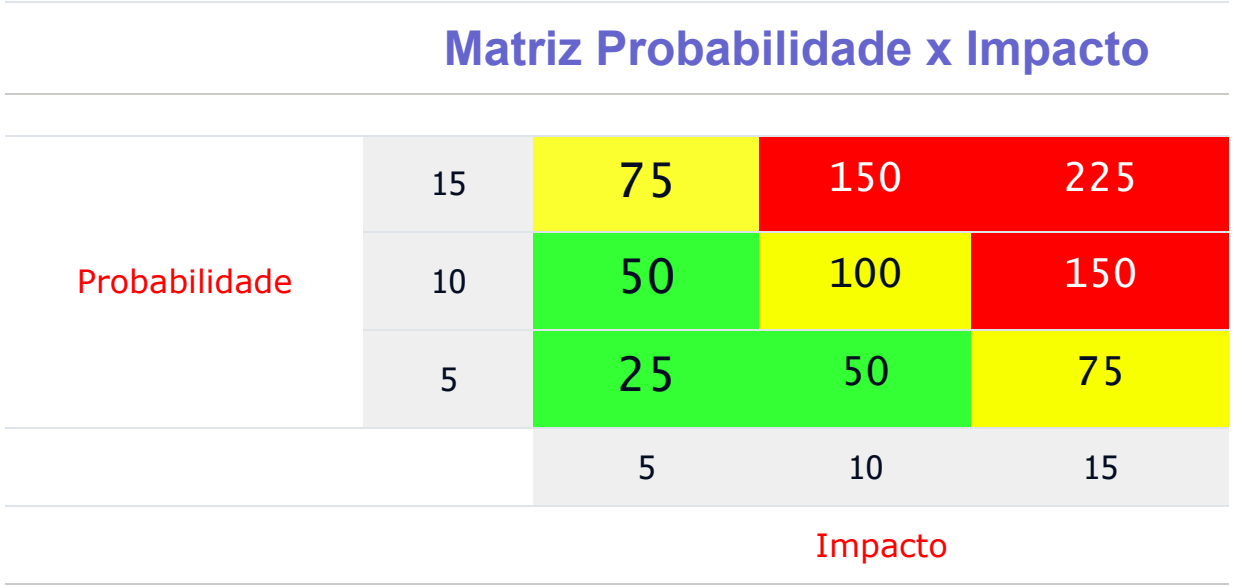
Impacto
consequência para titulares.

O modelo utiliza escala exemplificativa: **baixo = 5**, **moderado = 10**, **alto = 15**. O nível de risco resulta de **Probabilidade × Impacto**.

LGPD, Art. 5º, XVII.

Matriz de risco no RIPD

		IMPACTO		
		Baixo	**Moderado**	**Alto**
PROBABILIDADE		**5**	**10**	**15**
Alto	**15**	75	150	225
Moderado	**10**	50	100	150
Baixo	**5**	25	50	75



Matriz Probabilidade x Impacto (1)

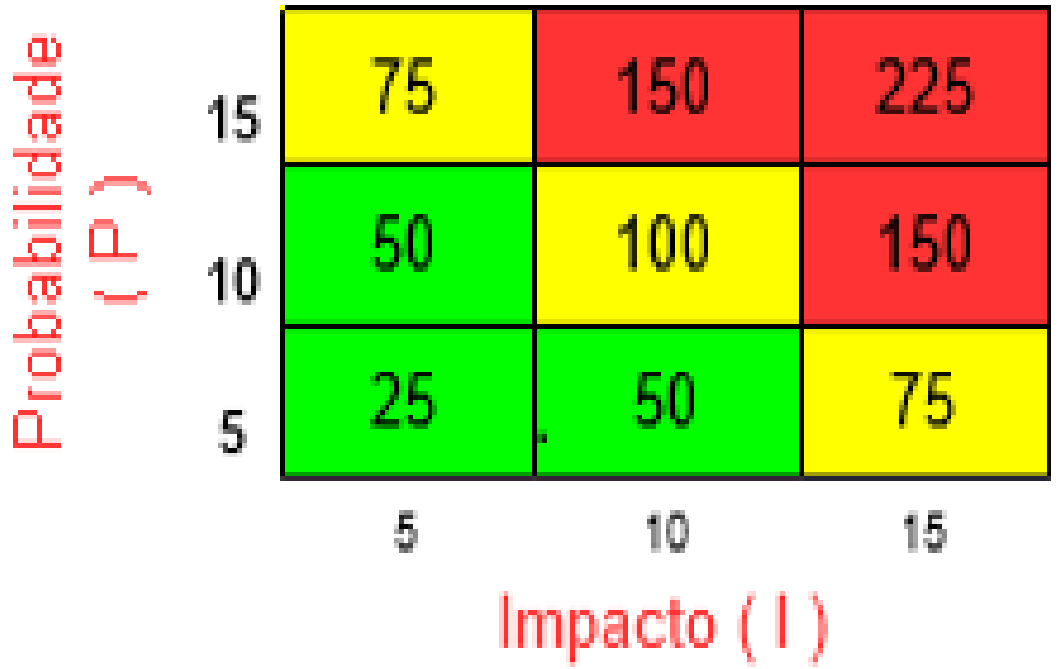


Figura 1: Matriz Probabilidade x Impacto

Matriz Probabilidade x Impacto (2)

PROBABILIDADE (frequência)	CONSEQUÊNCIA*				
	Desprezível (1)	Menor (2)	Moderada (4)	Maior (8)	Catastrófica (16)
Quase Certo (5)	5	10	20	40	80
Provável (4)	4	8	16	32	64
Possível (3)	3	6	12	24	48
Improvável (2)	2	4	8	16	32
Raro (1)	1	2	4	8	16

Fig. 17.1: Matriz Probabilidade x Impacto com 5 níveis de gradação.

A classificação deve considerar o dano potencial ao titular: discriminação, exposição indevida, fraude, prejuízo patrimonial, abalo moral, perda de confidencialidade ou restrição de direitos.

LGPD, Arts. 5º, XVII; 42; 46.

Exemplos de riscos de privacidade

Id	Risco	Possível impacto
R01	Acesso não autorizado	violação de confidencialidade
R06	Coleta excessiva	tratamento desnecessário e desproporcional
R07	Informação insuficiente sobre finalidade	violação de transparência
R09	Falha em considerar direitos do titular	restrição de exercício de direitos
R11	Retenção prolongada sem necessidade	aumento do risco de exposição
R14	Reidentificação de dados pseudoanonimizados	reversão indevida de proteção técnica

LGPD, Arts. 6º, III, VI e X; Art. 18; Art. 46.

Passo 8 — Definir medidas de tratamento dos riscos

As medidas podem ter natureza **técnica**, **administrativa**, **contratual**, **jurídica** ou **organizacional**.

Risco	Exemplo de medida	Efeito
Acesso não autorizado	controle de acesso, MFA, logs, revisão periódica	reduzir
Retenção excessiva	tabela de temporalidade e descarte seguro	reduzir
Compartilhamento indevido	cláusulas contratuais, registro de compartilhamento, base legal	reduzir
Risco inevitável	decisão formal de aceitar risco residual justificado	aceitar

LGPD, Art. 46; Art. 50, §2º, I.

Risco residual e decisão do controlador

Após aplicar controles, o RIPD deve indicar o **risco residual**.

Risco inerente → **controles** → risco residual → **decisão do controlador**

A decisão pode ser:

reduzir **evitar** **compartilhar** **aceitar**

Riscos altos podem exigir alteração do tratamento, reforço de controles, suspensão da iniciativa ou justificativa formal de aceitação.

LGPD, Arts. 6º, VII, VIII e X; Art. 46.

Passo 9 — Aprovar, publicar e revisar

Aprovação

Responsável pela elaboração, encarregado e representantes do controlador e operador.

Publicação

Em regra, não é automática; pode ser determinada pela ANPD ou avaliada conforme LAI e hipóteses de sigilo.

Revisão

Anual ou sempre que mudanças afetarem finalidade, escopo, tecnologia, risco ou base normativa.

LGPD, Arts. 6º, IV, VI e X; Art. 32; Art. 38.

Checklist mínimo de qualidade

Antes de concluir o RIPD, verificar se há:

1. Identificação completa dos agentes e do encarregado;
2. Justificativa objetiva para elaboração ou atualização;
3. Descrição da natureza, escopo, contexto e finalidade;
4. Indicação da hipótese legal aplicável;
5. Evidência de necessidade, adequação, minimização e transparência;
6. Consulta às partes interessadas;
7. Matriz de riscos e controles correspondentes;
8. Risco residual e aprovação formal;
9. Plano de revisão e monitoramento.

Erros frequentes a evitar

Erro 1

Descrever o sistema, mas não o tratamento de dados pessoais.

Erro 2

Usar base legal genérica sem vincular à finalidade concreta.

Erro 3

Listar controles sem relacioná-los a riscos específicos.

Erro 4

Ignorar retenção, descarte, compartilhamento e direitos dos titulares.

Um RIPD robusto deve permitir que terceiro qualificado compreenda o tratamento, os riscos, as decisões e as evidências.

Encerramento

RIPD é decisão documentada

- Não basta afirmar conformidade: é necessário demonstrar, com evidências, que o tratamento foi avaliado, que os riscos foram compreendidos e que as medidas foram aprovadas.

Referências normativas essenciais: LGPD, Arts. 5º, XVII; 6º; 7º; 10, §3º; 11; 14; 18; 20; 32; 38; 41; 46; 50.

Referências

- BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais — LGPD.
- BRASIL. Ministério da Gestão e da Inovação em Serviços Públicos. Secretaria de Governo Digital. **Guia/Modelo de Elaboração de Relatório de Impacto à Proteção de Dados Pessoais — RIPD**. Programa de Privacidade e Segurança da Informação — PPSI. Versão 2.0. Brasília, maio de 2023.
- ABNT. **ABNT NBR ISO/IEC 29134:2017** — Tecnologia da informação — Técnicas de segurança — Avaliação de impacto de privacidade — Diretrizes.
- ISO. **ISO 31000:2018** — Risk management — Guidelines.